ACME A3 REPORT

Group number: 09

Milillo Vincenzo 2215260
Zucconelli Giorgio 1966894
Altomare Andrea 2199451
Ruocco Salvatore 2222155

Practical Network Defense - Assignment 3

Initial brainstorming

We need to think about how to defend our network by hardening it. To “harden” a network means to apply many security measures so that, even if a single failure of these measures occurs, the network is still resilient to the attack because of other existing measures and tools.

When dealing with hardening, we mainly talk about three key areas to protect: Management plane (that is, the scope of network devices management), Control plane (support of the operations of network devices), and Data plane (operations of network devices). For each of these areas we need to implement one or more specific security measures in order to counteract possible attacks coming in the network.

The key components which we choose to work on are the IPS and IDS, but there also are other measures that can be implemented.

Protection plan definition

1. Configure the IDS/IPS Suricata on OPNsense
    - This will allow for the detection of eventual malicious behavior or for its prevention by the application of specific rules.
2. Change default passwords of machines and services
    - This will prevent bruteforce of weak passwords and password reuse attacks, and it’s mainly needed for the protection of the Management plane.
3. Access to OPNsense dashboard with HTTPS (no more HTTP)
    - This will encrypt the communication between the host and the firewall so that MITM attacks are harder to make.
4. Enable NTP on OPNsense
    - This is needed to set each host to the same time, as this operation enables an accounting and auditing of what is being done in the network at a certain time.
5. Generate logs from the hosts and collect them into log collector services.
    - This will enable auditing of what is being done in the network by each host.
6. Change openssl version in Webserver

Protection plan implementation & evaluation

1. IDS/IPS

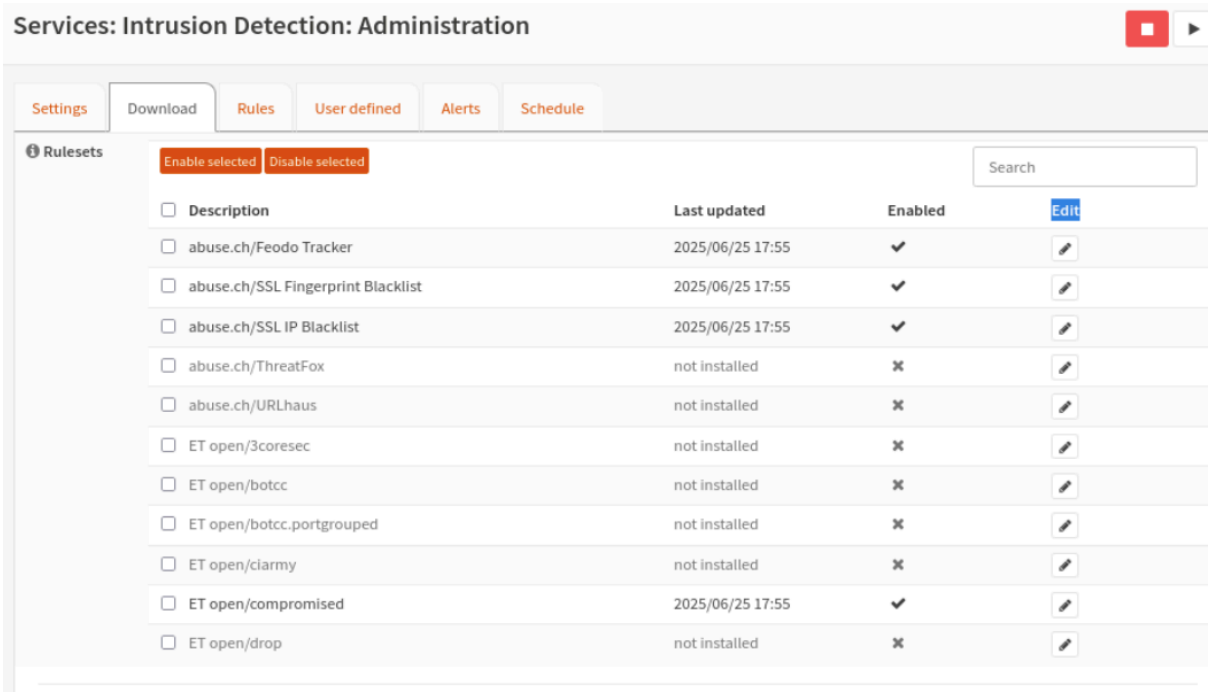
We followed this guide to configure **Suricata**.

Following the guide, in the Main firewall-router we go to Interfaces -> Settings and disable all the hardware offload and filtering options.

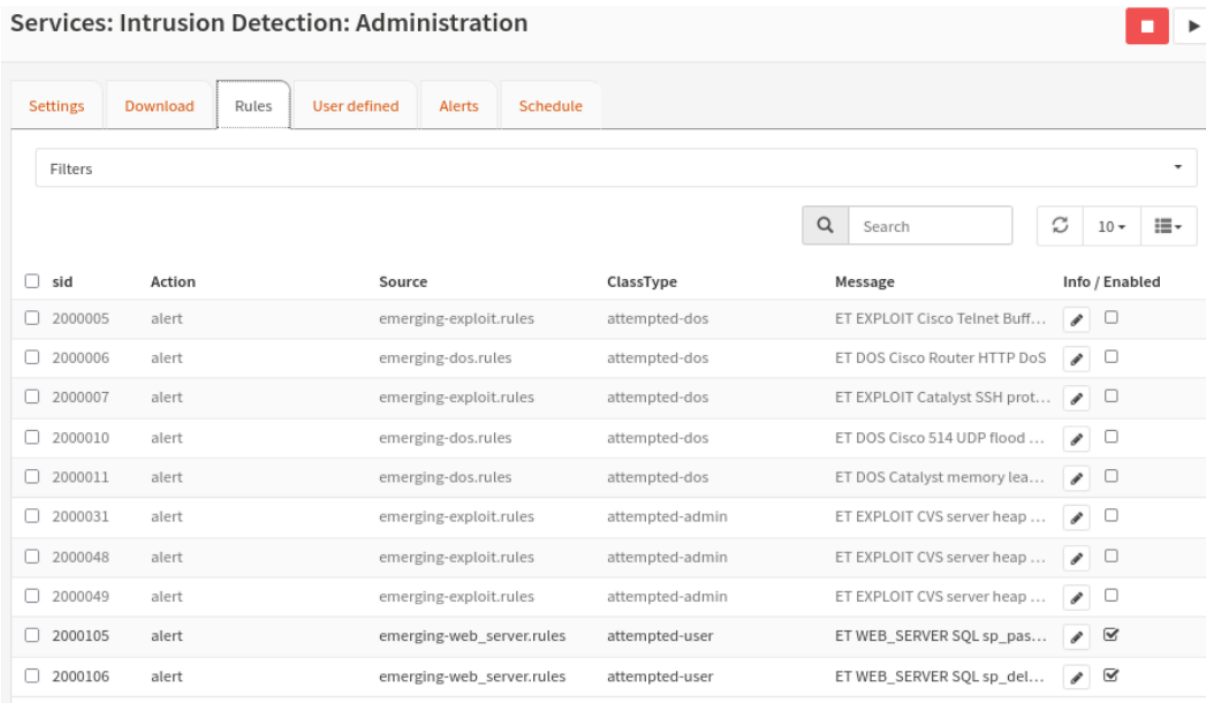
Then, we go to Services -> Intrusion detection -> Administration and enable the IDS integrated in OPNsense (enabling also IPS and promiscuous mode and syslog alerts). In the Home networks section, we put the address 100.100.0.0/16, meaning all the networks behind the Main firewall-router (that is, our network, that we want to defend).

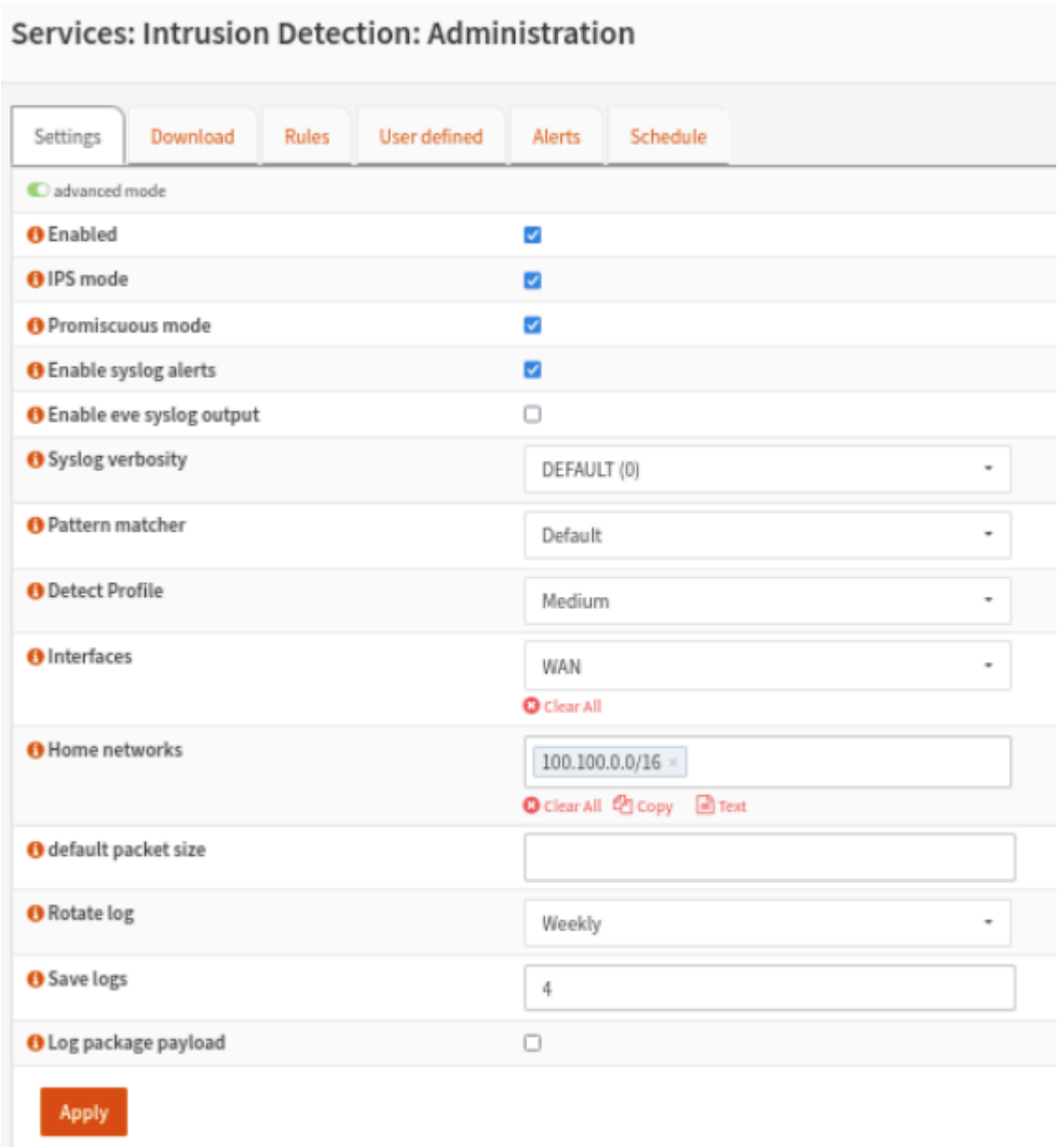
Note: the guide uses in the Pattern Matching field selects Hyperscan. If we do it in this manner, OPNsense returns an error when applying the configuration. Once we read this issue about ProxMox, we set Pattern Matching to Default.

Now we need to enable some rules for Suricata to protect the resources of our network. To do that, we go to Services -> Intrusion detection -> Administration, then go to “Download” tab. So, we select all the voices that are involved to the kind of resources we have in our network.



After downloading and updating the rules, we can check that the rules are enabled in the “Rules” tab, as can be seen below.


Services: Intrusion Detection: Administration
Settings
Download
Rules
User defined
Alerts
Schedule
Filters
Search
10
sid
Action
Source
ClassType
Message
Info / Enabled
2000005 alert emerging-exploit.rules attempted-dos ET EXPLOIT Cisco Telnet Buff…
2000006 alert emerging-dos.rules attempted-dos ET DOS Cisco Router HTTP DoS
2000007 alert emerging-exploit.rules attempted-dos ET EXPLOIT Catalyst SSH prot…
2000010 alert emerging-dos.rules attempted-dos ET DOS Cisco 514 UDP flood …
2000011 alert emerging-dos.rules attempted-dos ET DOS Catalyst memory lea…
2000031 alert emerging-exploit.rules attempted-admin ET EXPLOIT CVS server heap …
2000048 alert emerging-exploit.rules attempted-admin ET EXPLOIT CVS server heap …
2000049 alert emerging-exploit.rules attempted-admin ET EXPLOIT CVS server heap …
2000105 alert emerging-web_server.rules attempted-user ET WEB_SERVER SQL sp_pas…
2000106 alert emerging-web_server.rules attempted-user ET WEB_SERVER SQL sp_del…


Services: Intrusion Detection: Administration
Settings
Download
Rules
User defined
Alerts
Schedule
advanced mode
Enabled
IPS mode
Promiscuous mode
Enable syslog alerts
Enable eve syslog output
Syslog verbosity
DEFAULT (0)
Pattern matcher
Default
Detect Profile
Medium
Interfaces
WAN
Clear All
Home networks
100.100.0.0/16
Clear All
Copy
Text
default packet size
Rotate log
Weekly
Save logs
4
Log package payload
Apply

2. Change default passwords of machines and services

OPNsense passwords

Change the default password for user *root* on the two firewalls to access OPNsense.

- Main Firewall -> root : >p8[i61AS}>m
- Internal Firewall -> root : 8h=B6wF7J=$k

Hosts passwords

- arpwatch -> root : mnu&iHzEJ522
- dnsserver -> root : oD=:rBMO2-56
- logserver -> root : m94JFgC2{j)7
- greenbone -> root : *5h8)RhR?p82
- webserver -> root : 0Hg2b;8lK:[q
- proxyserver -> root : _k51B)I7D??u
- graylog -> root : kgyTtzX<73P1
- kali -> root : 2Jow@-85U]a8
- kali -> user : r]y;g1M15"@6

Service passwords

- graylog-> admin : _[Z4wzY463]C
- greenbone -> admin : 8ta3MV92$3pd

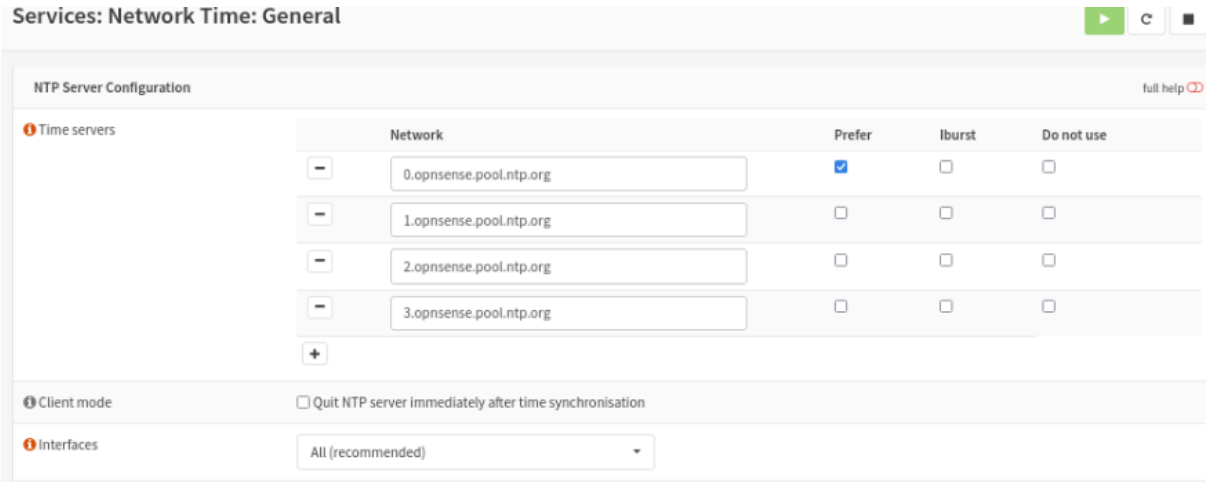
3. Access to OPNsense dashboard with HTTPS (no more HTTP)

Set both firewalls to be accessed only with https: under System->Settings->Administration set protocol to https.

In the same settings we also turned on “HTTP Strict Transport Security” for more protection, and “Disable web GUI redirect rule” so that users don’t get redirected from http to https but need to use https willingly.

4. Enable NTP on OPNsense

In the OPNsense dashboard, go to Services > Network Time > General, then set servers in the ‘Time Servers’ field and set ‘all’ in the ‘Interfaces’ field. We did this on both firewalls.



5. Generate logs from the hosts and collect them into log collector services

Setting **syslog** in the hosts was already done (for all hosts but Client network hosts) and allowing the traffic for Log server and Graylog server, in the first assignment (“*All the hosts (but the Client network hosts) have to use the syslog and the log collector services on the Log server (syslog) and Graylog server.*”).

On both firewalls System->Settings->Logging, add two remote entries, one to send logs to graylog and the other to send logs to the log server.

6. Change supported TLS versions on webserver.

The webserver was supporting TLS deprecated versions like 1.0 and 1.1.

We changed the relevant line in /etc/apache2/mods-available/ssl.conf to “SSLProtocol TLSv1.2 TLSv1.3” in order to only use versions 1.2 and 1.3.

Final remarks

Finally we think it was very useful to deal with the theoretical concepts of this course in a practical way, using tools that are highly sought after in the job market such as ProxMox and OPNsense.